

CVE-2023-52163 · Digiever DS-2105 Pro Missing Authorization Vulnerability Vendor: Digiever Product: DS-2105 Pro Vulnerability Description: Digiever DS-2105 Pro contains a missing authorization vulnerability which could allow for command injection via time_tzsetup.cgi. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-12-22 Remediation Due Date: 2026-01-12 Known Ransomware Use: Unknown Related CMMC/NIST Controls: AC-3 (Access Enforcement) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.digiever.com/tw/support/faq-content.php?FAQ=217> ; <https://nvd.nist.gov/vuln/detail/CVE-2023-52163>

CVE-2025-10585 · Google Chromium V8 Type Confusion Vulnerability Vendor: Google Product: Chromium V8 Vulnerability Description: Google Chromium contains a type confusion vulnerability in the V8 JavaScript and WebAssembly engine. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-09-23 Remediation Due Date: 2025-10-14 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://chromereleases.googleblog.com/2025/09/stable-channel-update-for-desktop_17.html ; <https://nvd.nist.gov/vuln/detail/CVE-2025-10585>

CVE-2017-0101 · Microsoft Windows Transaction Manager Privilege Escalation Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: A privilege escalation vulnerability exists when the Windows Transaction Manager improperly handles objects in memory. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-03-15 Remediation Due Date: 2022-04-05 Known Ransomware Use: Known Related CMMC/NIST Controls: SI-16 (Memory Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2017-0101>

CVE-2025-4008 · Smartbedded Meteobridge Command Injection Vulnerability Vendor: Smartbedded Product: Meteobridge Vulnerability Description: Smartbedded Meteobridge contains a command injection vulnerability that could allow remote unauthenticated attackers to gain arbitrary command execution with elevated privileges (root) on affected devices. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-10-02 Remediation Due Date: 2025-10-23 Known Ransomware Use: Unknown Related CMMC/NIST Controls: IA-2 (Missing Authentication) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://forum.meteohub.de/viewtopic.php?t=18687> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-4008>

CVE-2016-4437 · Apache Shiro Code Execution Vulnerability Vendor: Apache Product: Shiro Vulnerability Description: Apache Shiro contains a vulnerability which may allow remote attackers to execute code or bypass intended access restrictions via an unspecified request parameter when a cipher key has not been configured for the "remember me" feature. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2016-4437>

CVE-2023-28434 · MinIO Security Feature Bypass Vulnerability Vendor: MinIO Product: MinIO Vulnerability Description: MinIO contains a security feature bypass vulnerability that allows an attacker to use crafted requests to bypass metadata bucket name checking and put an object into any bucket while processing `PostPolicyBucket` to conduct privilege escalation. To carry out this

attack, the attacker requires credentials with `arn:aws:s3:::\*` permission, as well as enabled Console API access. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2023-09-19 Remediation Due Date: 2023-10-10 Known Ransomware Use: Unknown Related CMMC/NIST Controls: AC-6 (Least Privilege) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://github.com/minio/minio/security/advisories/GHSA-2pxw-r47w-4p8c>; <https://nvd.nist.gov/vuln/detail/CVE-2023-28434>

CVE-2014-8439 · Adobe Flash Player Dereferenced Pointer Vulnerability Vendor: Adobe Product: Flash Player Vulnerability Description: Adobe Flash Player has a vulnerability in the way it handles a dereferenced memory pointer which could lead to code execution. Required Action: The impacted product is end-of-life and should be disconnected if still in use. Date Added to KEV: 2022-05-25 Remediation Due Date: 2022-06-15 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Memory Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2014-8439>

CVE-2025-24085 · Apple Multiple Products Use-After-Free Vulnerability Vendor: Apple Product: Multiple Products Vulnerability Description: Apple iOS, macOS, and other Apple products contain a user-after-free vulnerability that could allow a malicious application to elevate privileges. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-01-29 Remediation Due Date: 2025-02-19 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Use-After-Free Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.apple.com/en-us/122066> ; <https://support.apple.com/en-us/122068> ; <https://support.apple.com/en-us/122071> ; <https://support.apple.com/en-us/122072> ; <https://support.apple.com/en-us/122073> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-24085>

CVE-2020-24363 · TP-link TL-WA855RE Missing Authentication for Critical Function Vulnerability Vendor: TP-Link Product: TL-WA855RE Vulnerability Description: TP-link TL-WA855RE contains a missing authentication for critical function vulnerability. This vulnerability could allow an unauthenticated attacker (on the same network) to submit a TDDP_RESET POST request for a factory reset and reboot. The attacker can then obtain incorrect access control by setting a new administrative password. The impacted products could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-09-02 Remediation Due Date: 2025-09-23 Known Ransomware Use: Unknown Related CMMC/NIST Controls: IA-2 (Missing Authentication) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.tp-link.com/us/home-networking/range-extender/tl-wa855re/#overview> ; <https://www.tp-link.com/us/support/download/tl-wa855re/#FAQs> ; <https://nvd.nist.gov/vuln/detail/CVE-2020-24363>

CVE-2011-1823 · Android OS Privilege Escalation Vulnerability Vendor: Android Product: Android OS Vulnerability Description: The vold volume manager daemon in Android kernel trusts messages from a PF_NETLINK socket, which allows an attacker to execute code and gain root privileges. This vulnerability is associated with GingerBreak and Exploit.AndroidOS.Lotoor. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-09-08 Remediation Due Date: 2022-09-29 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: [https://android.googlesource.com/platform/system/vold/+c51920c82463b240e2be0430849837d6fdc5352e](https://android.googlesource.com/platform/system/vold/+c51920c82463b240e2be0430849837d6fdc5352e;);

<https://nvd.nist.gov/vuln/detail/CVE-2011-1823>

CVE-2019-20500 · D-Link DWL-2600AP Access Point Command Injection Vulnerability Vendor: D-Link Product: DWL-2600AP Access Point Vulnerability Description: D-Link DWL-2600AP access point contains an authenticated command injection vulnerability via the Save Configuration functionality in the Web interface, using shell metacharacters in the `admin.cgi?action=config_save configBackup` or `downloadServerip` parameter. Required Action: Apply updates per vendor instructions or discontinue use of the product if updates are unavailable. Date Added to KEV: 2023-06-29 Remediation Due Date: 2023-07-20 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://supportannouncement.us.dlink.com/announcement/publication.aspx?name=SAP10113>; <https://nvd.nist.gov/vuln/detail/CVE-2019-20500>

CVE-2024-4577 · PHP-CGI OS Command Injection Vulnerability Vendor: PHP Group Product: PHP Vulnerability Description: PHP, specifically Windows-based PHP used in CGI mode, contains an OS command injection vulnerability that allows for arbitrary code execution. This vulnerability is a patch bypass for CVE-2012-1823. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-06-12 Remediation Due Date: 2024-07-03 Known Ransomware Use: Known Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability affects a common open-source component, third-party library, or a protocol used by different products. Please check with specific vendors for information on patching status. For more information, please see: <https://www.php.net/ChangeLog-8.php#>; <https://nvd.nist.gov/vuln/detail/CVE-2024-4577>

CVE-2025-40551 · SolarWinds Web Help Desk Deserialization of Untrusted Data Vulnerability Vendor: SolarWinds Product: Web Help Desk Vulnerability Description: SolarWinds Web Help Desk contains a deserialization of untrusted data vulnerability that could lead to remote code execution, which would allow an attacker to run commands on the host machine. This could be exploited without authentication. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2026-02-03 Remediation Due Date: 2026-02-06 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Deserialization Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.solarwinds.com/trust-center/security-advisories/cve-2025-40551> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-40551>

CVE-2024-53104 · Linux Kernel Out-of-Bounds Write Vulnerability Vendor: Linux Product: Kernel Vulnerability Description: Linux kernel contains an out-of-bounds write vulnerability in the `uvc_parse_streaming` component of the USB Video Class (UVC) driver that could allow for physical escalation of privilege. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-02-05 Remediation Due Date: 2025-02-26 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Out-of-Bounds Write Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability affects a common open-source component, third-party library, or a protocol used by different products. For more information, please see: <https://lore.kernel.org/linux-cve-announce/2024120232-CVE-2024-53104-d781@gregkh/> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-53104>

CVE-2023-45727 · North Grid Proself Improper Restriction of XML External Entity (XXE) Reference Vulnerability Vendor: North Grid Product: Proself Vulnerability Description: North Grid Proself Enterprise/Standard, Gateway, and Mail Sanitize contain an improper restriction of XML External

Entity (XXE) reference vulnerability, which could allow a remote, unauthenticated attacker to conduct an XXE attack. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-12-03 Remediation Due Date: 2024-12-24 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.proself.jp/information/153/> ; <https://nvd.nist.gov/vuln/detail/CVE-2023-45727>

CVE-2020-5735 · Amcrest Cameras and NVR Stack-based Buffer Overflow Vulnerability Vendor: Amcrest Product: Cameras and Network Video Recorder (NVR) Vulnerability Description: Amcrest cameras and NVR contain a stack-based buffer overflow vulnerability through port 37777 that allows an unauthenticated, remote attacker to crash the device and possibly execute code. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2020-5735>

CVE-2023-33063 · Qualcomm Multiple Chipsets Use-After-Free Vulnerability Vendor: Qualcomm Product: Multiple Chipsets Vulnerability Description: Multiple Qualcomm chipsets contain a use-after-free vulnerability due to memory corruption in DSP Services during a remote call from HLOS to DSP. Required Action: Apply remediations or mitigations per vendor instructions or discontinue use of the product if remediation or mitigations are unavailable. Date Added to KEV: 2023-12-05 Remediation Due Date: 2023-12-26 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Use-After-Free Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability affects a common open-source component, third-party library, or a protocol used by different products. Please check with specific vendors for information on patching status. For more information, please see: <https://git.codelinaro.org/clo/la/kernel/msm-5.15/-/commit/2643808ddbedfaabbb334741873fb2857f78188a>, <https://git.codelinaro.org/clo/la/kernel/msm-4.14/-/commit/d43222efda5a01c9804d74a541e3c1be9b7fe110>; <https://nvd.nist.gov/vuln/detail/CVE-2023-33063>

CVE-2024-37383 · RoundCube Webmail Cross-Site Scripting (XSS) Vulnerability Vendor: Roundcube Product: Webmail Vulnerability Description: RoundCube Webmail contains a cross-site scripting (XSS) vulnerability in the handling of SVG animate attributes that allows a remote attacker to run malicious JavaScript code. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-10-24 Remediation Due Date: 2024-11-14 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Cross-Site Scripting Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://github.com/roundcube/roundcubemail/releases/tag/1.5.7>, <https://github.com/roundcube/roundcubemail/releases/tag/1.6.7> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-37383>

CVE-2023-1671 · Sophos Web Appliance Command Injection Vulnerability Vendor: Sophos Product: Web Appliance Vulnerability Description: Sophos Web Appliance contains a command injection vulnerability in the warn-proceed handler that allows for remote code execution. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2023-11-16 Remediation Due Date: 2023-12-07 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.sophos.com/en-us/security-advisories/sophos-sa-20230404-swa-rce>; <https://nvd.nist.gov/vuln/detail/CVE-2023-1671>

CVE-2021-30661 · Apple Multiple Products WebKit Storage Use-After-Free Vulnerability Vendor: Apple

Product: Multiple Products Vulnerability Description: Apple iOS, iPadOS, macOS, tvOS, watchOS, and Safari WebKit Storage contain a use-after-free vulnerability that leads to code execution when processing maliciously crafted web content. This vulnerability could impact HTML parsers that use WebKit, including but not limited to Apple Safari and non-Apple products which rely on WebKit for HTML processing. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2021-11-17 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Use-After-Free Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2021-30661>

CVE-2018-4063 · Sierra Wireless AirLink ALEOS Unrestricted Upload of File with Dangerous Type Vulnerability Vendor: Sierra Wireless Product: AirLink ALEOS Vulnerability Description: Sierra Wireless AirLink ALEOS contains an unrestricted upload of file with dangerous type vulnerability. A specially crafted HTTP request can upload a file, resulting in executable code being uploaded, and routable, to the webserver. An attacker can make an authenticated HTTP request to trigger this vulnerability. The impacted product could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-12-12 Remediation Due Date: 2026-01-02 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Unrestricted Upload Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.cisa.gov/news-events/ics-advisories/icsa-19-122-03> ; https://source.sierrawireless.com/resources/airlink/software_reference_docs/technical-bulletin/sierra-wireless-technical-bulletin---swi-psa-2019-003 ; https://source.sierrawireless.com/resources/airlink/hardware_reference_docs/airlink_es450_eol ; <https://nvd.nist.gov/vuln/detail/CVE-2018-4063>

CVE-2024-50623 · Cleo Multiple Products Unrestricted File Upload Vulnerability Vendor: Cleo Product: Multiple Products Vulnerability Description: Cleo Harmony, VLTrader, and LexiCom, which are managed file transfer products, contain an unrestricted file upload and download vulnerability that can lead to remote code execution with elevated privileges. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-12-13 Remediation Due Date: 2025-01-03 Known Ransomware Use: Known Related CMMC/NIST Controls: SI-10 (Unrestricted Upload Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.cleo.com/hc/en-us/articles/28408134019735-Cleo-Product-Security-Update> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-50623>

CVE-2020-10181 · Sumavision EMR Cross-Site Request Forgery (CSRF) Vulnerability Vendor: Sumavision Product: Enhanced Multimedia Router (EMR) Vulnerability Description: Sumavision Enhanced Multimedia Router (EMR) contains a cross-site request forgery (CSRF) vulnerability allowing the creation of users with elevated privileges as administrator on a device. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2020-10181>

CVE-2020-5410 · VMware Tanzu Spring Cloud Config Directory Traversal Vulnerability Vendor: VMware Tanzu Product: Spring Cloud Configuration (Config) Server Vulnerability Description: Spring, by VMware Tanzu, Cloud Config contains a path traversal vulnerability that allows applications to serve arbitrary configuration files. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-03-25 Remediation Due Date: 2022-04-15 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities

that are actively exploited and require priority remediation under BOD 22-01. Notes:
<https://nvd.nist.gov/vuln/detail/CVE-2020-5410>

CVE-2025-54948 · Trend Micro Apex One OS Command Injection Vulnerability Vendor: Trend Micro
Product: Apex One Vulnerability Description: Trend Micro Apex One Management Console (on-premise)
contains an OS command injection vulnerability that could allow a pre-authenticated remote attacker
to upload malicious code and execute commands on affected installations. Required Action: Apply
mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or
discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-08-18
Remediation Due Date: 2025-09-08 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10
(Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability
management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV
catalog identifies vulnerabilities that are actively exploited and require priority remediation
under BOD 22-01. Notes: <https://success.trendmicro.com/en-US/solution/KA-0020652> ; N/A ;
<https://nvd.nist.gov/vuln/detail/CVE-2025-54948>

CVE-2009-3129 · Microsoft Excel Featheader Record Memory Corruption Vulnerability Vendor: Microsoft
Product: Excel Vulnerability Description: Microsoft Office Excel allows remote attackers to execute
arbitrary code via a spreadsheet with a FEATHEADER record containing an invalid cbHdrData size
element that affects a pointer offset. Required Action: Apply updates per vendor instructions. Date
Added to KEV: 2022-03-03 Remediation Due Date: 2022-03-24 Known Ransomware Use: Unknown Compliance
Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and
apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities
that are actively exploited and require priority remediation under BOD 22-01. Notes:
<https://nvd.nist.gov/vuln/detail/CVE-2009-3129>

CVE-2023-29492 · Novi Survey Insecure Deserialization Vulnerability Vendor: Novi Survey Product:
Novi Survey Vulnerability Description: Novi Survey contains an insecure deserialization
vulnerability that allows remote attackers to execute code on the server in the context of the
service account. Required Action: Apply updates per vendor instructions. Date Added to KEV:
2023-04-13 Remediation Due Date: 2023-05-04 Known Ransomware Use: Unknown Compliance Context:
Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply
security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are
actively exploited and require priority remediation under BOD 22-01. Notes:
<https://novisurvey.net/blog/novi-survey-security-advisory-apr-2023.aspx>;
<https://nvd.nist.gov/vuln/detail/CVE-2023-29492>

CVE-2024-44309 · Apple Multiple Products Cross-Site Scripting (XSS) Vulnerability Vendor: Apple
Product: Multiple Products Vulnerability Description: Apple iOS, macOS, and other Apple products
contain an unspecified vulnerability when processing maliciously crafted web content that may lead
to a cross-site scripting (XSS) attack. Required Action: Apply mitigations per vendor instructions
or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-11-21
Remediation Due Date: 2024-12-12 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10
(Cross-Site Scripting Prevention) Compliance Context: Organizations subject to CMMC must maintain
vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The
CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority
remediation under BOD 22-01. Notes: <https://support.apple.com/en-us/121752>,
<https://support.apple.com/en-us/121753>, <https://support.apple.com/en-us/121754>,
<https://support.apple.com/en-us/121755>, <https://support.apple.com/en-us/121756> ;
<https://nvd.nist.gov/vuln/detail/CVE-2024-44309>

CVE-2020-0618 · Microsoft SQL Server Reporting Services Remote Code Execution Vulnerability Vendor:
Microsoft Product: SQL Server Vulnerability Description: Microsoft SQL Server Reporting Services
contains a deserialization vulnerability when handling page requests incorrectly. An authenticated
attacker can exploit this vulnerability to execute code in the context of the Report Server service
account. Required Action: Apply mitigations per vendor instructions or discontinue use of the
product if mitigations are unavailable. Date Added to KEV: 2024-09-18 Remediation Due Date:
2024-10-09 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Deserialization
Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability
management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV

catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/en-US/advisory/CVE-2020-0618> ; <https://nvd.nist.gov/vuln/detail/CVE-2020-0618>

CVE-2024-4671 · Google Chromium Visuals Use-After-Free Vulnerability Vendor: Google Product: Chromium Vulnerability Description: Google Chromium Visuals contains a use-after-free vulnerability that allows a remote attacker to exploit heap corruption via a crafted HTML page. This vulnerability could affect multiple web browsers that utilize Chromium, including, but not limited to, Google Chrome, Microsoft Edge, and Opera. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-05-13 Remediation Due Date: 2024-06-03 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Use-After-Free Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://chromereleases.googleblog.com/2024/05/stable-channel-update-for-desktop_9.html?m=1; <https://nvd.nist.gov/vuln/detail/CVE-2024-4671>

CVE-2025-32709 · Microsoft Windows Ancillary Function Driver for WinSock Use-After-Free Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows Ancillary Function Driver for WinSock contains a use-after-free vulnerability that allows an authorized attacker to escalate privileges to administrator. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-05-13 Remediation Due Date: 2025-06-03 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Use-After-Free Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2025-32709> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-32709>

CVE-2019-0211 · Apache HTTP Server Privilege Escalation Vulnerability Vendor: Apache Product: HTTP Server Vulnerability Description: Apache HTTP Server, with MPM event, worker or prefork, code executing in less-privileged child processes or threads (including scripts executed by an in-process scripting interpreter) could execute code with the privileges of the parent process (usually root) by manipulating the scoreboard. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Use-After-Free Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2019-0211>

CVE-2022-30525 · Zyxel Multiple Firewalls OS Command Injection Vulnerability Vendor: Zyxel Product: Multiple Firewalls Vulnerability Description: A command injection vulnerability in the CGI program of some Zyxel firewall versions could allow an attacker to modify specific files and then execute some OS commands on a vulnerable device. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-05-16 Remediation Due Date: 2022-06-06 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2022-30525>

CVE-2024-53704 · SonicWall SonicOS SSLVPN Improper Authentication Vulnerability Vendor: SonicWall Product: SonicOS Vulnerability Description: SonicWall SonicOS contains an improper authentication vulnerability in the SSLVPN authentication mechanism that allows a remote attacker to bypass authentication. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-02-18 Remediation Due Date: 2025-03-11 Known Ransomware Use: Known Related CMMC/NIST Controls: IA-2 (Authentication Failures) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies

vulnerabilities that are actively exploited and require priority remediation under BOD 22-01.

Notes: <https://psirt.global.sonicwall.com/vuln-detail/SNWLID-2025-0003> ;

<https://nvd.nist.gov/vuln/detail/CVE-2024-53704>

CVE-2019-1458 · Microsoft Win32k Privilege Escalation Vulnerability Vendor: Microsoft Product: Win32k Vulnerability Description: A privilege escalation vulnerability exists in Windows when the Win32k component fails to properly handle objects in memory, aka 'Win32k EoP'. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-01-10 Remediation Due Date: 2022-07-10 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2019-1458>

CVE-2018-5430 · TIBCO JasperReports Server Information Disclosure Vulnerability Vendor: TIBCO Product: JasperReports Vulnerability Description: TIBCO JasperReports Server contain a vulnerability which may allow any authenticated user read-only access to the contents of the web application, including key configuration files. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-12-29 Remediation Due Date: 2023-01-19 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.tibco.com/support/advisories/2018/04/tibco-security-advisory-april-17-2018-tibco-jasperreports-2018-5430>; <https://nvd.nist.gov/vuln/detail/CVE-2018-5430>

CVE-2010-5326 · SAP NetWeaver Remote Code Execution Vulnerability Vendor: SAP Product: NetWeaver Vulnerability Description: SAP NetWeaver Application Server Java Platforms Invoker Servlet does not require authentication, allowing for remote code execution via a HTTP or HTTPS request. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2010-5326>

CVE-2024-41710 · Mitel SIP Phones Argument Injection Vulnerability Vendor: Mitel Product: SIP Phones Vulnerability Description: Mitel 6800 Series, 6900 Series, and 6900w Series SIP Phones, including the 6970 Conference Unit, contain an argument injection vulnerability due to insufficient parameter sanitization during the boot process. Successful exploitation may allow an attacker to execute arbitrary commands within the context of the system. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-02-12 Remediation Due Date: 2025-03-05 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://www.mitel.com/-/media/mitel/file/pdf/support/security-advisories/security-bulletin_24-0019-001-v2.pdf ; <https://nvd.nist.gov/vuln/detail/CVE-2024-41710>

CVE-2021-29256 · Arm Mali GPU Kernel Driver Use-After-Free Vulnerability Vendor: Arm Product: Mali Graphics Processing Unit (GPU) Vulnerability Description: Arm Mali GPU Kernel Driver contains a use-after-free vulnerability that may allow a non-privileged user to gain root privilege and/or disclose information. Required Action: Apply updates per vendor instructions or discontinue use of the product if updates are unavailable. Date Added to KEV: 2023-07-07 Remediation Due Date: 2023-07-28 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Use-After-Free Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://developer.arm.com/Arm%20Security%20Center/Mali%20GPU%20Driver%20Vulnerabilities>; <https://nvd.nist.gov/vuln/detail/CVE-2021-29256>

CVE-2019-15271 · Cisco RV Series Routers Deserialization of Untrusted Data Vulnerability Vendor:

Cisco Product: RV Series Routers Vulnerability Description: A deserialization of untrusted data vulnerability in the web-based management interface of certain Cisco Small Business RV Series Routers could allow an attacker to execute code with root privileges. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-06-08 Remediation Due Date: 2022-06-22 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Deserialization Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2019-15271>

CVE-2017-0022 · Microsoft XML Core Services Information Disclosure Vulnerability Vendor: Microsoft Product: XML Core Services Vulnerability Description: Microsoft XML Core Services (MSXML) improperly handles objects in memory, allowing attackers to test for files on disk via a crafted web site. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-05-24 Remediation Due Date: 2022-06-14 Known Ransomware Use: Unknown Related CMMC/NIST Controls: AC-4 (Information Flow Enforcement) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2017-0022>

CVE-2025-54313 · Prettier eslint-config-prettier Embedded Malicious Code Vulnerability Vendor: Prettier Product: eslint-config-prettier Vulnerability Description: Prettier eslint-config-prettier contains an embedded malicious code vulnerability. Installing an affected package executes an install.js file that launches the node-gyp.dll malware on Windows. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2026-01-22 Remediation Due Date: 2026-02-12 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability could affect an open-source component, third-party library, protocol, or proprietary implementation that could be used by different products. For more information, please see: <https://www.npmjs.com/package/eslint-config-prettier?activeTab=versions> ; <https://github.com/prettier/eslint-config-prettier/issues/339#issuecomment-3090304490> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-54313>

CVE-2016-20017 · D-Link DSL-2750B Devices Command Injection Vulnerability Vendor: D-Link Product: DSL-2750B Devices Vulnerability Description: D-Link DSL-2750B devices contain a command injection vulnerability that allows remote, unauthenticated command injection via the login.cgi cli parameter. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-01-08 Remediation Due Date: 2024-01-29 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://supportannouncement.us.dlink.com/announcement/publication.aspx?name=SAP10088>; <https://nvd.nist.gov/vuln/detail/CVE-2016-20017>

CVE-2025-30406 · Gladinet CentreStack and Triofox Use of Hard-coded Cryptographic Key Vulnerability Vendor: Gladinet Product: CentreStack Vulnerability Description: Gladinet CentreStack and Triofox contains a use of hard-coded cryptographic key vulnerability in the way that the application manages keys used for ViewState integrity verification. Successful exploitation allows an attacker to forge ViewState payloads for server-side deserialization, allowing for remote code execution. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-04-08 Remediation Due Date: 2025-04-29 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://gladinetsupport.s3.us-east-1.amazonaws.com/gladinet/securityadvisory-cve-2005.pdf> ; <https://gladinetsupport.s3.us-east-1.amazonaws.com/gladinet/securityadvisory-cve-2025-triofox.pdf> ;

<https://nvd.nist.gov/vuln/detail/CVE-2025-30406>

CVE-2022-27926 · Synacor Zimbra Collaboration Suite (ZCS) Cross-Site Scripting (XSS) Vulnerability
Vendor: Synacor Product: Zimbra Collaboration Suite (ZCS) Vulnerability Description: Synacor Zimbra Collaboration Suite (ZCS) contains a cross-site scripting vulnerability by allowing an endpoint URL to accept parameters without sanitizing. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2023-04-03 Remediation Due Date: 2023-04-24 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Cross-Site Scripting Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://wiki.zimbra.com/wiki/Security_Center; <https://nvd.nist.gov/vuln/detail/CVE-2022-27926>

CVE-2023-27992 · Zyxel Multiple NAS Devices Command Injection Vulnerability Vendor: Zyxel Product: Multiple Network-Attached Storage (NAS) Devices Vulnerability Description: Multiple Zyxel network-attached storage (NAS) devices contain a pre-authentication command injection vulnerability that could allow an unauthenticated attacker to execute commands remotely via a crafted HTTP request. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2023-06-23 Remediation Due Date: 2023-07-14 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.zyxel.com/global/en/support/security-advisories/zyxel-security-advisory-for-pre-authentication-command-injection-vulnerability-in-nas-products>; <https://nvd.nist.gov/vuln/detail/CVE-2023-27992>

CVE-2019-13608 · Citrix StoreFront Server XML External Entity (XXE) Processing Vulnerability Vendor: Citrix Product: StoreFront Server Vulnerability Description: Citrix StoreFront Server contains an XML External Entity (XXE) processing vulnerability that may allow an unauthenticated attacker to retrieve potentially sensitive information. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2019-13608>

CVE-2025-4427 · Ivanti Endpoint Manager Mobile (EPMM) Authentication Bypass Vulnerability Vendor: Ivanti Product: Endpoint Manager Mobile (EPMM) Vulnerability Description: Ivanti Endpoint Manager Mobile (EPMM) contains an authentication bypass vulnerability in the API component that allows an attacker to access protected resources without proper credentials via crafted API requests. This vulnerability results from an insecure implementation of the Spring Framework open-source library. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-05-19 Remediation Due Date: 2025-06-09 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://forums.ivanti.com/s/article/Security-Advisory-Ivanti-Endpoint-Manager-Mobile-EPMM> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-4427>

CVE-2020-8195 · Citrix ADC, Gateway, and SD-WAN WANOP Appliance Information Disclosure Vulnerability Vendor: Citrix Product: Application Delivery Controller (ADC), Gateway, and SD-WAN WANOP Appliance Vulnerability Description: Citrix ADC, Citrix Gateway, and multiple Citrix SD-WAN WANOP appliance models contain an information disclosure vulnerability. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2020-8195>

CVE-2024-20359 · Cisco ASA and FTD Privilege Escalation Vulnerability Vendor: Cisco Product: Adaptive Security Appliance (ASA) and Firepower Threat Defense (FTD) Vulnerability Description: Cisco Adaptive Security Appliance (ASA) and Firepower Threat Defense (FTD) contain a privilege escalation vulnerability that can allow local privilege escalation from Administrator to root. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-04-24 Remediation Due Date: 2024-05-01 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-asaftd-persist-rce-FLsNXF4h>; <https://nvd.nist.gov/vuln/detail/CVE-2024-20359>

CVE-2024-28987 · SolarWinds Web Help Desk Hardcoded Credential Vulnerability Vendor: SolarWinds Product: Web Help Desk Vulnerability Description: SolarWinds Web Help Desk contains a hardcoded credential vulnerability that could allow a remote, unauthenticated user to access internal functionality and modify data. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-10-15 Remediation Due Date: 2024-11-05 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.solarwinds.com/trust-center/security-advisories/cve-2024-28987> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-28987>

CVE-2025-31125 · Vite Vitejs Improper Access Control Vulnerability Vendor: Vite Product: Vitejs Vulnerability Description: Vite Vitejs contains an improper access control vulnerability that exposes content of non-allowed files using `?inline&import` or `?raw?import`. Only apps explicitly exposing the Vite dev server to the network (using `--host` or `server.host` config option) are affected. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2026-01-22 Remediation Due Date: 2026-02-12 Known Ransomware Use: Unknown Related CMMC/NIST Controls: AC-4 (Information Flow Enforcement) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability could affect an open-source component, third-party library, protocol, or proprietary implementation that could be used by different products. For more information, please see: <https://github.com/vitejs/vite/commit/59673137c45ac2bcfad1170d954347c1a17ab949> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-31125>

CVE-2024-42009 · RoundCube Webmail Cross-Site Scripting Vulnerability Vendor: Roundcube Product: Webmail Vulnerability Description: RoundCube Webmail contains a cross-site scripting vulnerability. This vulnerability could allow a remote attacker to steal and send emails of a victim via a crafted e-mail message that abuses a Desanitization issue in `message_body()` in `program/actions/mail/show.php`. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-06-09 Remediation Due Date: 2025-06-30 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Cross-Site Scripting Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://roundcube.net/news/2024/08/04/security-updates-1.6.8-and-1.5.8> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-42009>

CVE-2016-3643 · SolarWinds Virtualization Manager Privilege Escalation Vulnerability Vendor: SolarWinds Product: Virtualization Manager Vulnerability Description: SolarWinds Virtualization Manager allows for privilege escalation through leveraging a misconfiguration of `sudo`. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must

maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2016-3643>

CVE-2016-1010 · Adobe Flash Player and AIR Integer Overflow Vulnerability Vendor: Adobe Product: Flash Player and AIR Vulnerability Description: Integer overflow vulnerability in Adobe Flash Player and AIR allows attackers to execute code. Required Action: The impacted products are end-of-life and should be disconnected if still in use. Date Added to KEV: 2022-05-25 Remediation Due Date: 2022-06-15 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Integer Overflow Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2016-1010>

CVE-2018-20062 · ThinkPHP "noneCms" Remote Code Execution Vulnerability Vendor: ThinkPHP Product: noneCms Vulnerability Description: ThinkPHP "noneCms" contains an unspecified vulnerability that allows for remote code execution through crafted use of the filter parameter. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2018-20062>

CVE-2021-1906 · Qualcomm Multiple Chipsets Detection of Error Condition Without Action Vulnerability Vendor: Qualcomm Product: Multiple Chipsets Vulnerability Description: Multiple Qualcomm chipsets contain a detection of error condition without action vulnerability when improper handling of address deregistration on failure can lead to new GPU address allocation failure. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2021-11-17 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2021-1906>

CVE-2025-32433 · Erlang Erlang/OTP SSH Server Missing Authentication for Critical Function Vulnerability Vendor: Erlang Product: Erlang/OTP Vulnerability Description: Erlang Erlang/OTP SSH server contains a missing authentication for critical function vulnerability. This could allow an attacker to execute arbitrary commands without valid credentials, potentially leading to unauthenticated remote code execution (RCE). By exploiting a flaw in how SSH protocol messages are handled, a malicious actor could gain unauthorized access to affected systems. This vulnerability could affect various products that implement Erlang/OTP SSH server, including-but not limited to Cisco, NetApp, and SUSE. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-06-09 Remediation Due Date: 2025-06-30 Known Ransomware Use: Unknown Related CMMC/NIST Controls: IA-2 (Missing Authentication) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability affects a common open-source project, third-party library, or a protocol used by different products. For more information, please see: <https://github.com/erlang/otp/security/advisories/GHSA-37cp-fgq5-7wc2> ; <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-erlang-otp-ssh-xyZZy> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-32433>

CVE-2021-26855 · Microsoft Exchange Server Remote Code Execution Vulnerability Vendor: Microsoft Product: Exchange Server Vulnerability Description: Microsoft Exchange Server contains an unspecified vulnerability that allows for remote code execution. This vulnerability is part of the ProxyLogon exploit chain. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Known Related CMMC/NIST Controls: SC-7 (Server-Side Request Forgery Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited

and require priority remediation under BOD 22-01. Notes: Reference CISA's ED 21-02 (<https://www.cisa.gov/news-events/directives/ed-21-02-mitigate-microsoft-exchange-premises-product-vulnerabilities>) for further guidance and requirements. Note: The due date for addressing this vulnerability aligns with the requirements outlined in ED 21-02. <https://nvd.nist.gov/vuln/detail/CVE-2021-26855>

CVE-2025-6204 · Dassault Systèmes DELMIA Apriso Code Injection Vulnerability Vendor: Dassault Systèmes Product: DELMIA Apriso Vulnerability Description: Dassault Systèmes DELMIA Apriso contains a code injection vulnerability that could allow an attacker to execute arbitrary code. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-10-28 Remediation Due Date: 2025-11-18 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.3ds.com/trust-center/security/security-advisories/cve-2025-6204> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-6204>

CVE-2024-47575 · Fortinet FortiManager Missing Authentication Vulnerability Vendor: Fortinet Product: FortiManager Vulnerability Description: Fortinet FortiManager contains a missing authentication vulnerability in the fgmd daemon that allows a remote, unauthenticated attacker to execute arbitrary code or commands via specially crafted requests. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-10-23 Remediation Due Date: 2024-11-13 Known Ransomware Use: Unknown Related CMMC/NIST Controls: IA-2 (Missing Authentication) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://fortiguard.fortinet.com/psirt/FG-IR-24-423> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-47575>

CVE-2021-35395 · Realtek AP-Router SDK Buffer Overflow Vulnerability Vendor: Realtek Product: AP-Router SDK Vulnerability Description: Realtek AP-Router SDK HTTP web server boa contains a buffer overflow vulnerability due to unsafe copies of some overly long parameters submitted in the form that lead to denial-of-service (DoS). Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2021-11-17 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2021-35395>

CVE-2020-24557 · Trend Micro Multiple Products Improper Access Control Vulnerability Vendor: Trend Micro Product: Apex One, OfficeScan, and Worry-Free Business Security Vulnerability Description: Trend Micro Apex One, OfficeScan, and Worry-Free Business Security on Microsoft Windows contain an improper access control vulnerability that may allow an attacker to manipulate a particular product folder to disable the security temporarily, abuse a specific Windows function, and attain privilege escalation. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2020-24557>

CVE-2023-4966 · Citrix NetScaler ADC and NetScaler Gateway Buffer Overflow Vulnerability Vendor: Citrix Product: NetScaler ADC and NetScaler Gateway Vulnerability Description: Citrix NetScaler ADC and NetScaler Gateway contain a buffer overflow vulnerability that allows for sensitive information disclosure when configured as a Gateway (VPN virtual server, ICA Proxy, CVPN, RDP Proxy) or AAA virtual server. Required Action: Apply mitigations and kill all active and persistent sessions per vendor instructions [<https://www.netscaler.com/blog/news/cve-2023-4966-critical-security-update-now-available-for-netscaler-adc-and-netscaler-gateway/>] OR discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2023-10-18 Remediation Due Date: 2023-11-08 Known Ransomware

Use: Known Related CMMC/NIST Controls: SI-16 (Memory Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.netscaler.com/blog/news/cve-2023-4966-critical-security-update-now-available-for-netscaler-adc-and-netscaler-gateway/>, <https://support.citrix.com/article/CTX579459/netscaler-adc-and-netscaler-gateway-security-bulletin-for-cve20234966-and-cve20234967> ; <https://nvd.nist.gov/vuln/detail/CVE-2023-4966>

CVE-2010-0232 · Microsoft Windows Kernel Exception Handler Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: The kernel in Microsoft Windows, when access to 16-bit applications is enabled on a 32-bit x86 platform, does not properly validate certain BIOS calls, which allows local users to gain privileges. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-03-03 Remediation Due Date: 2022-03-24 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2010-0232>

CVE-2026-21533 · Microsoft Windows Improper Privilege Management Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows Remote Desktop Services contains an improper privilege management vulnerability that could allow an authorized attacker to elevate privileges locally. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2026-02-10 Remediation Due Date: 2026-03-03 Known Ransomware Use: Unknown Related CMMC/NIST Controls: AC-6 (Least Privilege) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-21533> ; <https://nvd.nist.gov/vuln/detail/CVE-2026-21533>

CVE-2025-10035 · Fortra GoAnywhere MFT Deserialization of Untrusted Data Vulnerability Vendor: Fortra Product: GoAnywhere MFT Vulnerability Description: Fortra GoAnywhere MFT contains a deserialization of untrusted data vulnerability allows an actor with a validly forged license response signature to deserialize an arbitrary actor-controlled object, possibly leading to command injection. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-09-29 Remediation Due Date: 2025-10-20 Known Ransomware Use: Known Related CMMC/NIST Controls: SI-10 (Deserialization Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.fortra.com/security/advisories/product-security/fi-2025-012> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-10035>

CVE-2017-16651 · Roundcube Webmail File Disclosure Vulnerability Vendor: Roundcube Product: Roundcube Webmail Vulnerability Description: Roundcube Webmail contains a file disclosure vulnerability caused by insufficient input validation in conjunction with file-based attachment plugins, which are used by default. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2017-16651>

CVE-2015-1130 · Apple OS X Authentication Bypass Vulnerability Vendor: Apple Product: OS X Vulnerability Description: The XPC implementation in Admin Framework in Apple OS X before 10.10.3 allows local users to bypass authentication and obtain admin privileges. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-02-10 Remediation Due Date: 2022-08-10

Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2015-1130>

CVE-2014-6271 · GNU Bourne-Again Shell (Bash) Arbitrary Code Execution Vulnerability Vendor: GNU Product: Bourne-Again Shell (Bash) Vulnerability Description: GNU Bash through 4.3 processes trailing strings after function definitions in the values of environment variables, which allows remote attackers to execute code. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-01-28 Remediation Due Date: 2022-07-28 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2014-6271>

CVE-2013-2597 · Code Aurora ACDB Audio Driver Stack-based Buffer Overflow Vulnerability Vendor: Code Aurora Product: ACDB Audio Driver Vulnerability Description: The Code Aurora audio calibration database (acdb) audio driver contains a stack-based buffer overflow vulnerability that allows for privilege escalation. Code Aurora is used in third-party products such as Qualcomm and Android. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-09-15 Remediation Due Date: 2022-10-06 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Memory Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://web.archive.org/web/20161226013354/https://www.codeaurora.org/news/security-advisories/stack-based-buffer-overflow-acdb-audio-driver-cve-2013-2597>; <https://nvd.nist.gov/vuln/detail/CVE-2013-2597>

CVE-2022-23176 · WatchGuard Firebox and XTM Privilege Escalation Vulnerability Vendor: WatchGuard Product: Firebox and XTM Vulnerability Description: WatchGuard Firebox and XTM appliances allow a remote attacker with unprivileged credentials to access the system with a privileged management session via exposed management access. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-04-11 Remediation Due Date: 2022-05-02 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2022-23176>

CVE-2024-3400 · Palo Alto Networks PAN-OS Command Injection Vulnerability Vendor: Palo Alto Networks Product: PAN-OS Vulnerability Description: Palo Alto Networks PAN-OS GlobalProtect feature contains a command injection vulnerability that allows an unauthenticated attacker to execute commands with root privileges on the firewall. Required Action: Apply mitigations per vendor instructions as they become available. Otherwise, users with vulnerable versions of affected devices should enable Threat Prevention IDs available from the vendor. See the vendor bulletin for more details and a patch release schedule. Date Added to KEV: 2024-04-12 Remediation Due Date: 2024-04-19 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://security.paloaltonetworks.com/CVE-2024-3400> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-3400>

CVE-2025-40602 · SonicWall SMA1000 Missing Authorization Vulnerability Vendor: SonicWall Product: SMA1000 appliance Vulnerability Description: SonicWall SMA1000 contains a missing authorization vulnerability that could allow for privilege escalation appliance management console (AMC) of affected devices. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable Date Added to KEV: 2025-12-17 Remediation Due Date: 2025-12-24 Known Ransomware Use: Unknown Related CMMC/NIST Controls: AC-3 (Access Enforcement) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely

manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: Check for signs of potential compromise on all internet accessible SonicWall SMA1000 instances after applying mitigations. For more information please see: <https://psirt.global.sonicwall.com/vuln-detail/SNWLID-2025-0019> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-40602>

CVE-2025-33053 · Microsoft Windows External Control of File Name or Path Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows contains an external control of file name or path vulnerability that could allow an attacker to execute code from a remote WebDAV location specified by the WorkingDirectory attribute of Internet Shortcut files. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-06-10 Remediation Due Date: 2025-07-01 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2025-33053> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-33053>

CVE-2024-51378 · CyberPanel Incorrect Default Permissions Vulnerability Vendor: CyberPersons Product: CyberPanel Vulnerability Description: CyberPanel contains an incorrect default permissions vulnerability that allows for authentication bypass and the execution of arbitrary commands using shell metacharacters in the statusfile property. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-12-04 Remediation Due Date: 2024-12-25 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://cyberpanel.net/KnowledgeBase/home/change-logs/> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-51378>

CVE-2025-2775 · SysAid On-Prem Improper Restriction of XML External Entity Reference Vulnerability Vendor: SysAid Product: SysAid On-Prem Vulnerability Description: SysAid On-Prem contains an improper restriction of XML external entity reference vulnerability in the Checkin processing functionality, allowing for administrator account takeover and file read primitives. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-07-22 Remediation Due Date: 2025-08-12 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://documentation.sysaid.com/docs/24-40-60> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-2775>

CVE-2022-42827 · Apple iOS and iPadOS Out-of-Bounds Write Vulnerability Vendor: Apple Product: iOS and iPadOS Vulnerability Description: Apple iOS and iPadOS kernel contain an out-of-bounds write vulnerability which can allow an application to perform code execution with kernel privileges. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-10-25 Remediation Due Date: 2022-11-15 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Out-of-Bounds Write Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.apple.com/en-us/HT213489>; <https://nvd.nist.gov/vuln/detail/CVE-2022-42827>

CVE-2023-41992 · Apple Multiple Products Kernel Privilege Escalation Vulnerability Vendor: Apple Product: Multiple Products Vulnerability Description: Apple iOS, iPadOS, macOS, and watchOS contain an unspecified vulnerability that allows for local privilege escalation. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2023-09-25 Remediation Due Date: 2023-10-16 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management

processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.apple.com/en-us/HT213926>, <https://support.apple.com/en-us/HT213927>, <https://support.apple.com/en-us/HT213928>, <https://support.apple.com/en-us/HT213929>, <https://support.apple.com/en-us/HT213931>, <https://support.apple.com/en-us/HT213932>; <https://nvd.nist.gov/vuln/detail/CVE-2023-41992>

CVE-2018-13382 · Fortinet FortiOS and FortiProxy Improper Authorization Vendor: Fortinet Product: FortiOS and FortiProxy Vulnerability Description: An Improper Authorization vulnerability in Fortinet FortiOS and FortiProxy under SSL VPN web portal allows an unauthenticated attacker to modify the password. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-01-10 Remediation Due Date: 2022-07-10 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2018-13382>

CVE-2025-24201 · Apple Multiple Products WebKit Out-of-Bounds Write Vulnerability Vendor: Apple Product: Multiple Products Vulnerability Description: Apple iOS, iPadOS, macOS, and other Apple products contain an out-of-bounds write vulnerability in WebKit that may allow maliciously crafted web content to break out of Web Content sandbox. This vulnerability could impact HTML parsers that use WebKit, including but not limited to Apple Safari and non-Apple products which rely on WebKit for HTML processing. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-03-13 Remediation Due Date: 2025-04-03 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Out-of-Bounds Write Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.apple.com/en-us/122281> ; <https://support.apple.com/en-us/122283> ; <https://support.apple.com/en-us/122284> ; <https://support.apple.com/en-us/122285> ; ; <https://nvd.nist.gov/vuln/detail/CVE-2025-24201>

CVE-2024-40711 · Veeam Backup and Replication Deserialization Vulnerability Vendor: Veeam Product: Backup & Replication Vulnerability Description: Veeam Backup and Replication contains a deserialization vulnerability allowing an unauthenticated user to perform remote code execution. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-10-17 Remediation Due Date: 2024-11-07 Known Ransomware Use: Known Related CMMC/NIST Controls: SI-10 (Deserialization Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.veeam.com/kb4649> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-40711>

CVE-2019-12991 · Citrix SD-WAN and NetScaler Command Injection Vulnerability Vendor: Citrix Product: SD-WAN and NetScaler Vulnerability Description: Authenticated Command Injection in Citrix SD-WAN Appliance and NetScaler SD-WAN Appliance. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-03-25 Remediation Due Date: 2022-04-15 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2019-12991>

CVE-2025-24990 · Microsoft Windows Untrusted Pointer Dereference Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows Agere Modem Driver contains an untrusted pointer dereference vulnerability that allows for privilege escalation. An attacker who successfully exploited this vulnerability could gain administrator privileges. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-10-14

Remediation Due Date: 2025-11-04 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2025-24990> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-24990>

CVE-2020-25079 · D-Link DCS-2530L and DCS-2670L Command Injection Vulnerability Vendor: D-Link Product: DCS-2530L and DCS-2670L Devices Vulnerability Description: D-Link DCS-2530L and DCS-2670L devices contains a command injection vulnerability in the cgi-bin/ddns_enc.cgi. The impacted products could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-08-05 Remediation Due Date: 2025-08-26 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.dlink.com/productinfo.aspx?m=DCS-2530L> ; <https://supportannouncement.us.dlink.com/announcement/publication.aspx?name=SAP10180> ; <https://nvd.nist.gov/vuln/detail/CVE-2020-25079>

CVE-2025-0411 · 7-Zip Mark of the Web Bypass Vulnerability Vendor: 7-Zip Product: 7-Zip Vulnerability Description: 7-Zip contains a protection mechanism failure vulnerability that allows remote attackers to bypass the Mark-of-the-Web security feature to execute arbitrary code in the context of the current user. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-02-06 Remediation Due Date: 2025-02-27 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.7-zip.org/history.txt> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-0411>

CVE-2024-9465 · Palo Alto Networks Expedition SQL Injection Vulnerability Vendor: Palo Alto Networks Product: Expedition Vulnerability Description: Palo Alto Networks Expedition contains a SQL injection vulnerability that allows an unauthenticated attacker to reveal Expedition database contents, such as password hashes, usernames, device configurations, and device API keys. With this, attackers can also create and read arbitrary files on the Expedition system. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-11-14 Remediation Due Date: 2024-12-05 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (SQL Injection Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://security.paloaltonetworks.com/PAN-SA-2024-0010> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-9465>

CVE-2024-54085 · AMI MegaRAC SPx Authentication Bypass by Spoofing Vulnerability Vendor: AMI Product: MegaRAC SPx Vulnerability Description: AMI MegaRAC SPx contains an authentication bypass by spoofing vulnerability in the Redfish Host Interface. A successful exploitation of this vulnerability may lead to a loss of confidentiality, integrity, and/or availability. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-06-25 Remediation Due Date: 2025-07-16 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability could affect an open-source component, third-party library, protocol, or proprietary implementation that could be used by different products. For more information, please see: <https://go.ami.com/hubfs/Security%20Advisories/2025/AMI-SA-2025003.pdf> ; <https://security.netapp.com/advisory/ntap-20250328-0003/> ;

<https://nvd.nist.gov/vuln/detail/CVE-2024-54085>

CVE-2025-59287 · Microsoft Windows Server Update Service (WSUS) Deserialization of Untrusted Data Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows Server Update Service (WSUS) contains a deserialization of untrusted data vulnerability that allows for remote code execution. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-10-24 Remediation Due Date: 2025-11-14 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Deserialization Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2025-59287> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-59287>

CVE-2023-22952 · Multiple SugarCRM Products Remote Code Execution Vulnerability Vendor: SugarCRM Product: Multiple Products Vulnerability Description: Multiple SugarCRM products contain a remote code execution vulnerability in the EmailTemplates. Using a specially crafted request, custom PHP code can be injected through the EmailTemplates. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2023-02-02 Remediation Due Date: 2023-02-23 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.sugarcrm.com/Resources/Security/sugarcrm-sa-2023-001/>; <https://nvd.nist.gov/vuln/detail/CVE-2023-22952>

CVE-2025-53690 · Sitecore Multiple Products Deserialization of Untrusted Data Vulnerability Vendor: Sitecore Product: Multiple Products Vulnerability Description: Sitecore Experience Manager (XM), Experience Platform (XP), Experience Commerce (XC), and Managed Cloud contain a deserialization of untrusted data vulnerability involving the use of default machine keys. This flaw allows attackers to exploit exposed ASP.NET machine keys to achieve remote code execution. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-09-04 Remediation Due Date: 2025-09-25 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Deserialization Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://support.sitecore.com/kb?id=kb_article_view&sysparm_article=KB1003865 ; <https://nvd.nist.gov/vuln/detail/CVE-2025-53690>

CVE-2021-28799 · QNAP NAS Improper Authorization Vulnerability Vendor: QNAP Product: Network Attached Storage (NAS) Vulnerability Description: QNAP NAS running HBS 3 contains an improper authorization vulnerability which can allow remote attackers to log in to a device. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-03-31 Remediation Due Date: 2022-04-21 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2021-28799>

CVE-2020-11023 · JQuery Cross-Site Scripting (XSS) Vulnerability Vendor: JQuery Product: JQuery Vulnerability Description: JQuery contains a persistent cross-site scripting (XSS) vulnerability. When passing maliciously formed, untrusted input enclosed in HTML tags, JQuery's DOM manipulators can execute untrusted code in the context of the user's browser. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-01-23 Remediation Due Date: 2025-02-13 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Cross-Site Scripting Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability could affect an open-source

component, third-party library, protocol, or proprietary implementation that could be used by different products. For more information, please see:

<https://github.com/jquery/jquery/security/advisories/GHSA-jpcq-cgw6-v4j6> ;

<https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/> ;

<https://nvd.nist.gov/vuln/detail/CVE-2020-11023>

CVE-2010-3765 · Mozilla Multiple Products Remote Code Execution Vulnerability Vendor: Mozilla Product: Multiple Products Vulnerability Description: Mozilla Firefox, SeaMonkey, and Thunderbird contain an unspecified vulnerability when JavaScript is enabled. This allows remote attackers to execute arbitrary code via vectors related to nsCSSFrameConstructor::ContentAppended, the appendChild method, incorrect index tracking, and the creation of multiple frames, which triggers memory corruption. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-10-06 Remediation Due Date: 2025-10-27 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.mozilla.org/en-US/security/advisories/mfsa2010-73> ; <https://nvd.nist.gov/vuln/detail/CVE-2010-3765>

CVE-2022-23227 · NUUO NVRmini2 Devices Missing Authentication Vulnerability Vendor: NUUO Product: NVRmini2 Devices Vulnerability Description: NUUO NVRmini2 devices contain a missing authentication vulnerability that allows an unauthenticated attacker to upload an encrypted TAR archive, which can be abused to add arbitrary users. Required Action: The impacted product is end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue utilization of the product. Date Added to KEV: 2024-12-18 Remediation Due Date: 2025-01-08 Known Ransomware Use: Unknown Related CMMC/NIST Controls: IA-2 (Missing Authentication) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nuuo.com/wp-content/uploads/2023/03/NUUO-EOL-letter-NVRmini-2-and-NVRsolo-series.pdf> ; <https://nvd.nist.gov/vuln/detail/CVE-2022-23227>

CVE-2019-3396 · Atlassian Confluence Server and Data Center Server-Side Template Injection Vulnerability Vendor: Atlassian Product: Confluence Server and Data Server Vulnerability Description: Atlassian Confluence Server and Data Center contain a server-side template injection vulnerability that may allow an attacker to achieve path traversal and remote code execution. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2019-3396>

CVE-2023-29300 · Adobe ColdFusion Deserialization of Untrusted Data Vulnerability Vendor: Adobe Product: ColdFusion Vulnerability Description: Adobe ColdFusion contains a deserialization of untrusted data vulnerability that allows for code execution. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-01-08 Remediation Due Date: 2024-01-29 Known Ransomware Use: Known Related CMMC/NIST Controls: SI-10 (Deserialization Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://helpx.adobe.com/security/products/coldfusion/apsb23-40.html>; <https://nvd.nist.gov/vuln/detail/CVE-2023-29300>

CVE-2015-0016 · Microsoft Windows TS WebProxy Directory Traversal Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Directory traversal vulnerability in the TS WebProxy (TSWbPrxy) component in Microsoft Windows allows remote attackers to escalate privileges. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-05-25 Remediation Due Date: 2022-06-15 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner

(SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2015-0016>

CVE-2025-59718 · Fortinet Multiple Products Improper Verification of Cryptographic Signature Vulnerability Vendor: Fortinet Product: Multiple Products Vulnerability Description: Fortinet FortiOS, FortiSwitchMaster, FortiProxy, and FortiWeb contain an improper verification of cryptographic signature vulnerability that may allow an unauthenticated attacker to bypass the FortiCloud SSO login authentication via a crafted SAML message. Please be aware that CVE-2025-59719 pertains to the same problem and is mentioned in the same vendor advisory. Ensure to apply all patches mentioned in the advisory. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-12-16 Remediation Due Date: 2025-12-23 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://fortiguard.fortinet.com/psirt/FG-IR-25-647> ; <https://docs.fortinet.com/upgrade-tool/fortigate> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-59718>

CVE-2024-4879 · ServiceNow Improper Input Validation Vulnerability Vendor: ServiceNow Product: Utah, Vancouver, and Washington DC Now Platform Vulnerability Description: ServiceNow Utah, Vancouver, and Washington DC Now Platform releases contain a jelly template injection vulnerability in UI macros. An unauthenticated user could exploit this vulnerability to execute code remotely. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-07-29 Remediation Due Date: 2024-08-19 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://support.servicenow.com/kb?id=kb_article_view&sysparm_article=KB1645154; <https://nvd.nist.gov/vuln/detail/CVE-2024-4879>

CVE-2010-3035 · Cisco IOS XR Border Gateway Protocol (BGP) Denial-of-Service Vulnerability Vendor: Cisco Product: IOS XR Vulnerability Description: Cisco IOS XR, when BGP is the configured routing feature, allows remote attackers to cause a denial-of-service (DoS). Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-03-25 Remediation Due Date: 2022-04-15 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2010-3035>

CVE-2013-0648 · Adobe Flash Player Code Execution Vulnerability Vendor: Adobe Product: Flash Player Vulnerability Description: Adobe Flash Player contains an unspecified vulnerability in the ExternalInterface ActionScript functionality that allows a remote attacker to execute arbitrary code via crafted SWF content. Required Action: The impacted product is end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue utilization of the product. Date Added to KEV: 2024-09-17 Remediation Due Date: 2024-10-08 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.adobe.com/products/flashplayer/end-of-life-alternative.html#eol-alternative-faq> ; <https://nvd.nist.gov/vuln/detail/CVE-2013-0648>

CVE-2019-18935 · Progress Telerik UI for ASP.NET AJAX Deserialization of Untrusted Data Vulnerability Vendor: Progress Product: Telerik UI for ASP.NET AJAX Vulnerability Description: Progress Telerik UI for ASP.NET AJAX contains a deserialization of untrusted data vulnerability through RadAsyncUpload which leads to code execution on the server in the context of the w3wp.exe process. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Known Related CMMC/NIST Controls: SI-10 (Deserialization Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The

CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2019-18935>

CVE-2021-38000 · Google Chromium Intents Improper Input Validation Vulnerability Vendor: Google Product: Chromium Intents Vulnerability Description: Google Chromium Intents contains an improper input validation vulnerability that allows a remote attacker to arbitrarily browser to a malicious URL via a crafted HTML page. This vulnerability could affect multiple web browsers that utilize Chromium, including, but not limited to, Google Chrome, Microsoft Edge, and Opera. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2021-11-17 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2021-38000>

CVE-2016-1646 · Google Chromium V8 Out-of-Bounds Read Vulnerability Vendor: Google Product: Chromium V8 Vulnerability Description: Google Chromium V8 Engine contains an out-of-bounds read vulnerability that allows a remote attacker to cause a denial of service or possibly have another unspecified impact via crafted JavaScript code. This vulnerability could affect multiple web browsers that utilize Chromium, including, but not limited to, Google Chrome, Microsoft Edge, and Opera. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-06-08 Remediation Due Date: 2022-06-22 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Memory Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2016-1646>

CVE-2017-12615 · Apache Tomcat on Windows Remote Code Execution Vulnerability Vendor: Apache Product: Tomcat Vulnerability Description: When running Apache Tomcat on Windows with HTTP PUTs enabled, it is possible to upload a JSP file to the server via a specially crafted request. This JSP could then be requested and any code it contained would be executed by the server. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-03-25 Remediation Due Date: 2022-04-15 Known Ransomware Use: Known Related CMMC/NIST Controls: SI-10 (Unrestricted Upload Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2017-12615>

CVE-2019-17026 · Mozilla Firefox And Thunderbird Type Confusion Vulnerability Vendor: Mozilla Product: Firefox and Thunderbird Vulnerability Description: Mozilla Firefox and Thunderbird contain a type confusion vulnerability due to incorrect alias information in the IonMonkey JIT compiler when setting array elements. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2019-17026>

CVE-2014-1812 · Microsoft Windows Group Policy Preferences Password Privilege Escalation Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows Active Directory contains a privilege escalation vulnerability due to the way it distributes passwords that are configured using Group Policy preferences. An authenticated attacker who successfully exploits the vulnerability could decrypt the passwords and use them to elevate privileges on the domain. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2014-1812>

CVE-2025-48384 · Git Link Following Vulnerability Vendor: Git Product: Git Vulnerability

Description: Git contains a link following vulnerability that stems from Git's inconsistent handling of carriage return characters in configuration files. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-08-25 Remediation Due Date: 2025-09-15 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability affects a common open-source component, third-party library, or a protocol used by different products. For more information, please see: <https://github.com/git/git/security/advisories/GHSA-vwqx-4fm8-6qc9> ; <https://access.redhat.com/errata/RHSA-2025:13933> ; <https://alas.aws.amazon.com/AL2/ALAS2-2025-2941.html> ; <https://linux.oracle.com/errata/ELSA-2025-11534.html> ; <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2025-48384> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-48384>

CVE-2025-54309 · CrushFTP Unprotected Alternate Channel Vulnerability Vendor: CrushFTP Product: CrushFTP Vulnerability Description: CrushFTP contains an unprotected alternate channel vulnerability. When the DMZ proxy feature is not used, mishandles AS2 validation and consequently allows remote attackers to obtain admin access via HTTPS. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-07-22 Remediation Due Date: 2025-08-12 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.crushftp.com/crush11wiki/Wiki.jsp?page=CompromiseJuly2025> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-54309>

CVE-2022-20821 · Cisco IOS XR Open Port Vulnerability Vendor: Cisco Product: IOS XR Vulnerability Description: Cisco IOS XR software health check opens TCP port 6379 by default on activation. An attacker can connect to the Redis instance on the open port and allow access to the Redis instance that is running within the NOSi container. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-05-23 Remediation Due Date: 2022-06-13 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2022-20821>

CVE-2024-11182 · MDaemon Email Server Cross-Site Scripting (XSS) Vulnerability Vendor: MDaemon Product: Email Server Vulnerability Description: MDaemon Email Server contains a cross-site scripting (XSS) vulnerability that allows a remote attacker to load arbitrary JavaScript code via an HTML e-mail message. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-05-19 Remediation Due Date: 2025-06-09 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Cross-Site Scripting Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://files.mdaemon.com/mdaemon/beta/RelNotes_en.html ; <https://mdaemon.com/pages/downloads-critical-updates> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-11182>

CVE-2024-28986 · SolarWinds Web Help Desk Deserialization of Untrusted Data Vulnerability Vendor: SolarWinds Product: Web Help Desk Vulnerability Description: SolarWinds Web Help Desk contains a deserialization of untrusted data vulnerability that could allow for remote code execution. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-08-15 Remediation Due Date: 2024-09-05 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Deserialization Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes:

<https://www.solarwinds.com/trust-center/security-advisories/cve-2024-28986>;
<https://nvd.nist.gov/vuln/detail/CVE-2024-28986>

CVE-2021-22900 · Ivanti Pulse Connect Secure Unrestricted File Upload Vulnerability Vendor: Ivanti Product: Pulse Connect Secure Vulnerability Description: Ivanti Pulse Connect Secure contains an unrestricted file upload vulnerability that allows an authenticated administrator to perform a file write via a maliciously crafted archive upload in the administrator web interface. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: Reference CISA's ED 21-03 (<https://www.cisa.gov/news-events/directives/ed-21-03-mitigate-pulse-connect-secure-product-vulnerabilities>) for further guidance and requirements. Note: The due date for addressing this vulnerability aligns with the requirements outlined in ED 21-03. <https://nvd.nist.gov/vuln/detail/CVE-2021-22900>

CVE-2013-3163 · Microsoft Internet Explorer Memory Corruption Vulnerability Vendor: Microsoft Product: Internet Explorer Vulnerability Description: Microsoft Internet Explorer contains a memory corruption vulnerability that allows remote attackers to execute code or cause a denial of service via a crafted website. Required Action: The impacted product is end-of-life and should be disconnected if still in use. Date Added to KEV: 2023-03-30 Remediation Due Date: 2023-04-20 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://learn.microsoft.com/en-us/security-updates/securitybulletins/2013/ms13-055>; <https://nvd.nist.gov/vuln/detail/CVE-2013-3163>

CVE-2024-49039 · Microsoft Windows Task Scheduler Privilege Escalation Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows Task Scheduler contains a privilege escalation vulnerability that can allow an attacker-provided, local application to escalate privileges outside of its AppContainer, and access privileged RPC functions. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-11-12 Remediation Due Date: 2024-12-03 Known Ransomware Use: Known Related CMMC/NIST Controls: IA-2 (Authentication Failures) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2024-49039> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-49039>

CVE-2024-37085 · VMware ESXi Authentication Bypass Vulnerability Vendor: VMware Product: ESXi Vulnerability Description: VMware ESXi contains an authentication bypass vulnerability. A malicious actor with sufficient Active Directory (AD) permissions can gain full access to an ESXi host that was previously configured to use AD for user management by re-creating the configured AD group ('ESXi Admins' by default) after it was deleted from AD. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-07-30 Remediation Due Date: 2024-08-20 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/24505>; <https://nvd.nist.gov/vuln/detail/CVE-2024-37085>

CVE-2023-32046 · Microsoft Windows MSHTML Platform Privilege Escalation Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows MSHTML Platform contains an unspecified vulnerability that allows for privilege escalation. Required Action: Apply updates per vendor instructions or discontinue use of the product if updates are unavailable. Date Added to KEV: 2023-07-11 Remediation Due Date: 2023-08-01 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply

security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes:
<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2023-32046>;
<https://nvd.nist.gov/vuln/detail/CVE-2023-32046>

CVE-2025-8110 · Gogs Path Traversal Vulnerability Vendor: Gogs Product: Gogs Vulnerability Description: Gogs contains a path traversal vulnerability affecting improper Symbolic link handling in the PutContents API that could allow for code execution. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2026-01-12 Remediation Due Date: 2026-02-02 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes:
<https://github.com/gogs/gogs/commit/553707f3fd5f68f47f531cfcff56aa3ec294c6f6> ;
<https://nvd.nist.gov/vuln/detail/CVE-2025-8110>

CVE-2025-47827 · IGEL OS Use of a Key Past its Expiration Date Vulnerability Vendor: IGEL Product: IGEL OS Vulnerability Description: IGEL OS contains a use of a key past its expiration date vulnerability that allows for Secure Boot bypass. The igel-flash-driver module improperly verifies a cryptographic signature. Ultimately, a crafted root filesystem can be mounted from an unverified SquashFS image. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-10-14 Remediation Due Date: 2025-11-04 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2025-47827> ;
<https://nvd.nist.gov/vuln/detail/CVE-2025-47827>

CVE-2012-4792 · Microsoft Internet Explorer Use-After-Free Vulnerability Vendor: Microsoft Product: Internet Explorer Vulnerability Description: Microsoft Internet Explorer contains a use-after-free vulnerability that allows a remote attacker to execute arbitrary code via a crafted web site that triggers access to an object that (1) was not properly allocated or (2) is deleted, as demonstrated by a CDwnBindInfo object. Required Action: The impacted product is end-of-life and should be disconnected if still in use. Date Added to KEV: 2024-07-23 Remediation Due Date: 2024-08-13 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Use-After-Free Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes:
<https://learn.microsoft.com/en-us/lifecycle/products/internet-explorer-11>;
<https://nvd.nist.gov/vuln/detail/CVE-2012-4792>

CVE-2024-40766 · SonicWall SonicOS Improper Access Control Vulnerability Vendor: SonicWall Product: SonicOS Vulnerability Description: SonicWall SonicOS contains an improper access control vulnerability that could lead to unauthorized resource access and, under certain conditions, may cause the firewall to crash. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-09-09 Remediation Due Date: 2024-09-30 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes:
<https://psirt.global.sonicwall.com/vuln-detail/SNWLID-2024-0015>;
<https://www.sonicwall.com/support/notices/gen-7-and-newer-sonicwall-firewalls-sslvpn-recent-threat-activity/ka1VN000000RDG0A2> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-40766>

CVE-2017-6742 · Cisco IOS and IOS XE Software SNMP Remote Code Execution Vulnerability Vendor: Cisco Product: IOS and IOS XE Software Vulnerability Description: The Simple Network Management Protocol (SNMP) subsystem of Cisco IOS and IOS XE contains a vulnerability that could allow an authenticated, remote attacker to remotely execute code on an affected system or cause an affected

system to reload. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2023-04-19 Remediation Due Date: 2023-05-10 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Memory Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-20170629-snmip>; <https://nvd.nist.gov/vuln/detail/CVE-2017-6742>

CVE-2025-1976 · Broadcom Brocade Fabric OS Code Injection Vulnerability Vendor: Broadcom Product: Brocade Fabric OS Vulnerability Description: Broadcom Brocade Fabric OS contains a code injection vulnerability that allows a local user with administrative privileges to execute arbitrary code with full root privileges. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-04-28 Remediation Due Date: 2025-05-19 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/25602> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-1976>

CVE-2023-41991 · Apple Multiple Products Improper Certificate Validation Vulnerability Vendor: Apple Product: Multiple Products Vulnerability Description: Apple iOS, iPadOS, macOS, and watchOS contain an improper certificate validation vulnerability that can allow a malicious app to bypass signature validation. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2023-09-25 Remediation Due Date: 2023-10-16 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.apple.com/en-us/HT213926>, <https://support.apple.com/en-us/HT213927>, <https://support.apple.com/en-us/HT213928>, <https://support.apple.com/en-us/HT213929>, <https://support.apple.com/en-us/HT213931> ; <https://nvd.nist.gov/vuln/detail/CVE-2023-41991>

CVE-2007-3010 · Alcatel OmniPCX Enterprise Remote Code Execution Vulnerability Vendor: Alcatel Product: OmniPCX Enterprise Vulnerability Description: masterCGI in the Unified Maintenance Tool in Alcatel OmniPCX Enterprise Communication Server allows remote attackers to execute arbitrary commands. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-04-15 Remediation Due Date: 2022-05-06 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2007-3010>

CVE-2017-12232 · Cisco IOS Software for Cisco Integrated Services Routers Denial-of-Service Vulnerability Vendor: Cisco Product: IOS software Vulnerability Description: A vulnerability in the implementation of a protocol in Cisco Integrated Services Routers Generation 2 (ISR G2) Routers running Cisco IOS could allow an unauthenticated, adjacent attacker to cause an affected device to reload, resulting in a denial of service. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-03-03 Remediation Due Date: 2022-03-24 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2017-12232>

CVE-2010-3904 · Linux Kernel Improper Input Validation Vulnerability Vendor: Linux Product: Kernel Vulnerability Description: Linux Kernel contains an improper input validation vulnerability in the Reliable Datagram Sockets (RDS) protocol implementation that allows local users to gain privileges via crafted use of the sendmsg and recvmsg system calls. Required Action: The impacted product is

end-of-life and should be disconnected if still in use. Date Added to KEV: 2023-05-12 Remediation Due Date: 2023-06-02 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://lkml.iu.edu/hypermail/linux/kernel/1601.3/06474.html>; <https://nvd.nist.gov/vuln/detail/CVE-2010-3904>

CVE-2025-9377 · TP-Link Archer C7(EU) and TL-WR841N/ND(MS) OS Command Injection Vulnerability Vendor: TP-Link Product: Multiple Routers Vulnerability Description: TP-Link Archer C7(EU) and TL-WR841N/ND(MS) contain an OS command injection vulnerability that exists in the Parental Control page. The impacted products could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-09-03 Remediation Due Date: 2025-09-24 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.tp-link.com/us/support/faq/4308/> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-9377>

CVE-2022-37055 · D-Link Routers Buffer Overflow Vulnerability Vendor: D-Link Product: Routers Vulnerability Description: D-Link Routers contains a buffer overflow vulnerability that has a high impact on confidentiality, integrity, and availability. The impacted products could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-12-08 Remediation Due Date: 2025-12-29 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Buffer Overflow Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://supportannouncement.us.dlink.com/security/publication.aspx?name=SAP10308> ; <https://nvd.nist.gov/vuln/detail/CVE-2022-37055>

CVE-2025-42599 · Qualitia Active! Mail Stack-Based Buffer Overflow Vulnerability Vendor: Qualitia Product: Active! Mail Vulnerability Description: Qualitia Active! Mail contains a stack-based buffer overflow vulnerability that allows a remote, unauthenticated attacker to execute arbitrary or trigger a denial-of-service via a specially crafted request. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-04-28 Remediation Due Date: 2025-05-19 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://www.qualitia.com/jp/news/2025/04/18_1030.html ; <https://nvd.nist.gov/vuln/detail/CVE-2025-42599>

CVE-2022-28810 · Zoho ManageEngine ADSelfService Plus Remote Code Execution Vulnerability Vendor: Zoho Product: ManageEngine Vulnerability Description: Zoho ManageEngine ADSelfService Plus contains an unspecified vulnerability allowing for remote code execution when performing a password change or reset. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2023-03-07 Remediation Due Date: 2023-03-28 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.manageengine.com/products/self-service-password/advisory/CVE-2022-28810.html>; <https://nvd.nist.gov/vuln/detail/CVE-2022-28810>

CVE-2020-14871 · Oracle Solaris and Zettabyte File System (ZFS) Unspecified Vulnerability Vendor: Oracle Product: Solaris and Zettabyte File System (ZFS) Vulnerability Description: Oracle Solaris

and Oracle ZFS Storage Appliance Kit contain an unspecified vulnerability causing high impacts to confidentiality, integrity, and availability of affected systems. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Out-of-Bounds Write Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2020-14871>

CVE-2026-24061 · GNU InetUtils Argument Injection Vulnerability Vendor: GNU Product: InetUtils Vulnerability Description: GNU InetUtils contains an argument injection vulnerability in telnetd that could allow for remote authentication bypass via a "-f root" value for the USER environment variable. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2026-01-26 Remediation Due Date: 2026-02-16 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability could affect an open-source component, third-party library, protocol, or proprietary implementation that could be used by different products. For more information, please see: <https://cgit.git.savannah.gnu.org/cgit/inetutils.git> ; <https://codeberg.org/inetutils/inetutils/commit/ccba9f748aa8d50a38d7748e2e60362edd6a32cc>; <https://codeberg.org/inetutils/inetutils/commit/fd702c02497b2f398e739e3119bed0b23dd7aa7b> ; <https://nvd.nist.gov/vuln/detail/CVE-2026-24061>

CVE-2023-2136 · Google Chrome Skia Integer Overflow Vulnerability Vendor: Google Product: Chromium Skia Vulnerability Description: Google Chromium Skia contains an integer overflow vulnerability that allows a remote attacker, who has compromised the renderer process, to potentially perform a sandbox escape via a crafted HTML page. This vulnerability affects Google Chrome and ChromeOS, Android, Flutter, and possibly other products. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2023-04-21 Remediation Due Date: 2023-05-12 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Integer Overflow Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://chromereleases.googleblog.com/2023/04/stable-channel-update-for-desktop_18.html; <https://nvd.nist.gov/vuln/detail/CVE-2023-2136>

CVE-2016-8735 · Apache Tomcat Remote Code Execution Vulnerability Vendor: Apache Product: Tomcat Vulnerability Description: Apache Tomcat contains an unspecified vulnerability that allows for remote code execution if JmxRemoteLifecycleListener is used and an attacker can reach Java Management Extension (JMX) ports. This CVE exists because this listener wasn't updated for consistency with the Oracle patched issues for CVE-2016-3427 which affected credential types. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2023-05-12 Remediation Due Date: 2023-06-02 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://tomcat.apache.org/security-9.html>; <https://nvd.nist.gov/vuln/detail/CVE-2016-8735>

CVE-2022-26134 · Atlassian Confluence Server and Data Center Remote Code Execution Vulnerability Vendor: Atlassian Product: Confluence Server/Data Center Vulnerability Description: Atlassian Confluence Server and Data Center contain a remote code execution vulnerability that allows for an unauthenticated attacker to perform remote code execution. Required Action: Immediately block all internet traffic to and from affected products AND apply the update per vendor instructions [<https://confluence.atlassian.com/doc/confluence-security-advisory-2022-06-02-1130377146.html>] OR remove the affected products by the due date on the right. Note: Once the update is successfully deployed, agencies can reassess the internet blocking rules. Date Added to KEV: 2022-06-02 Remediation Due Date: 2022-06-06 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches

in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes:
<https://nvd.nist.gov/vuln/detail/CVE-2022-26134>

CVE-2023-20109 · Cisco IOS and IOS XE Group Encrypted Transport VPN Out-of-Bounds Write Vulnerability Vendor: Cisco Product: IOS and IOS XE Vulnerability Description: Cisco IOS and IOS XE contain an out-of-bounds write vulnerability in the Group Encrypted Transport VPN (GET VPN) feature that could allow an authenticated, remote attacker who has administrative control of either a group member or a key server to execute malicious code or cause a device to crash. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2023-10-10 Remediation Due Date: 2023-10-31 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Out-of-Bounds Write Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes:
<https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-getvpn-rce-g8qR68sx>; <https://nvd.nist.gov/vuln/detail/CVE-2023-20109>

CVE-2018-14933 · NUUO NVRmini Devices OS Command Injection Vulnerability Vendor: NUUO Product: NVRmini Devices Vulnerability Description: NUUO NVRmini devices contain an OS command injection vulnerability. This vulnerability allows remote command execution via shell metacharacters in the uploadaddr parameter for a writeuploadaddr command. Required Action: The impacted product is end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue utilization of the product. Date Added to KEV: 2024-12-18 Remediation Due Date: 2025-01-08 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nuuo.com/wp-content/uploads/2023/03/NUUO-EOL-letter%E2%82%AC%80NVRmini-2-and-NVRsolo-series.pdf> ; <https://nvd.nist.gov/vuln/detail/CVE-2018-14933>

CVE-2025-62215 · Microsoft Windows Race Condition Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows Kernel contains a race condition vulnerability that allows a local attacker with low-level privileges to escalate privileges. Successful exploitation of this vulnerability could enable the attacker to gain SYSTEM-level access. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-11-12 Remediation Due Date: 2025-12-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes:
<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2025-62215> ;
<https://nvd.nist.gov/vuln/detail/CVE-2025-62215>

CVE-2013-2596 · Linux Kernel Integer Overflow Vulnerability Vendor: Linux Product: Kernel Vulnerability Description: Linux kernel fb_mmap function in drivers/video/fbmem.c contains an integer overflow vulnerability that allows for privilege escalation. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-09-15 Remediation Due Date: 2022-10-06 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://git.kernel.org/pub/scm/linux/kernel/git/torvalds/linux.git/commit/?id=fc9bbca8f650e5f738af8806317c0a041a48ae4a>;
<https://nvd.nist.gov/vuln/detail/CVE-2013-2596>

CVE-2022-23134 · Zabbix Frontend Improper Access Control Vulnerability Vendor: Zabbix Product: Frontend Vulnerability Description: Malicious actors can pass step checks and potentially change the configuration of Zabbix Frontend. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-02-22 Remediation Due Date: 2022-03-08 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities

that are actively exploited and require priority remediation under BOD 22-01. Notes:
<https://nvd.nist.gov/vuln/detail/CVE-2022-23134>

CVE-2023-38831 · RARLAB WinRAR Code Execution Vulnerability Vendor: RARLAB Product: WinRAR
Vulnerability Description: RARLAB WinRAR contains an unspecified vulnerability that allows an attacker to execute code when a user attempts to view a benign file within a ZIP archive. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2023-08-24 Remediation Due Date: 2023-09-14 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: http://www.win-rar.com/singlenewsview.html?&L=0&tx_ttnews%5Btt_news%5D=232&cHash=c5bf79590657e32554c6683296a8e8aa;
<https://nvd.nist.gov/vuln/detail/CVE-2023-38831>

CVE-2024-37079 · Broadcom VMware vCenter Server Out-of-bounds Write Vulnerability Vendor: Broadcom Product: VMware vCenter Server Vulnerability Description: Broadcom VMware vCenter Server contains an out-of-bounds write vulnerability in the implementation of the DCERPC protocol. This could allow a malicious actor with network access to vCenter Server to send specially crafted network packets, potentially leading to remote code execution. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2026-01-23 Remediation Due Date: 2026-02-13 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Out-of-Bounds Write Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/24453> ;
<https://nvd.nist.gov/vuln/detail/CVE-2024-37079>

CVE-2025-41244 · Broadcom VMware Aria Operations and VMware Tools Privilege Defined with Unsafe Actions Vulnerability Vendor: Broadcom Product: VMware Aria Operations and VMware Tools
Vulnerability Description: Broadcom VMware Aria Operations and VMware Tools contain a privilege defined with unsafe actions vulnerability. A malicious local actor with non-administrative privileges having access to a VM with VMware Tools installed and managed by Aria Operations with SDMP enabled may exploit this vulnerability to escalate privileges to root on the same VM. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-10-30 Remediation Due Date: 2025-11-20 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/36149> ;
<https://nvd.nist.gov/vuln/detail/CVE-2025-41244>

CVE-2021-38406 · Delta Electronics DOPSoft 2 Improper Input Validation Vulnerability Vendor: Delta Electronics Product: DOPSoft 2 Vulnerability Description: Delta Electronics DOPSoft 2 lacks proper validation of user-supplied data when parsing specific project files (improper input validation) resulting in an out-of-bounds write that allows for code execution. Required Action: The impacted product is end-of-life and should be disconnected if still in use. Date Added to KEV: 2022-08-25 Remediation Due Date: 2022-09-15 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Out-of-Bounds Write Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: [https://www.cisa.gov/uscert/ics/advisories/icsa-21-252-02;](https://www.cisa.gov/uscert/ics/advisories/icsa-21-252-02)
<https://nvd.nist.gov/vuln/detail/CVE-2021-38406>

CVE-2009-0557 · Microsoft Office Object Record Corruption Vulnerability Vendor: Microsoft Product: Office Vulnerability Description: Microsoft Office contains an object record corruption

vulnerability that allows remote attackers to execute code via a crafted Excel file with a malformed record object. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-06-08 Remediation Due Date: 2022-06-22 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2009-0557>

CVE-2014-4077 · Microsoft IME Japanese Privilege Escalation Vulnerability Vendor: Microsoft Product: Input Method Editor (IME) Japanese Vulnerability Description: Microsoft Input Method Editor (IME) Japanese is a keyboard with Japanese characters that can be enabled on Windows systems as it is included by default (with the default set as disabled). IME Japanese contains an unspecified vulnerability when IMJPDCT.EXE (IME for Japanese) is installed which allows attackers to bypass a sandbox and perform privilege escalation. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-05-25 Remediation Due Date: 2022-06-15 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2014-4077>

CVE-2023-35078 · Ivanti Endpoint Manager Mobile Authentication Bypass Vulnerability Vendor: Ivanti Product: Endpoint Manager Mobile (EPMM) Vulnerability Description: Ivanti Endpoint Manager Mobile (EPMM, previously branded MobileIron Core) contains an authentication bypass vulnerability that allows unauthenticated access to specific API paths. An attacker with access to these API paths can access personally identifiable information (PII) such as names, phone numbers, and other mobile device details for users on a vulnerable system. An attacker can also make other configuration changes including installing software and modifying security profiles on registered devices. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2023-07-25 Remediation Due Date: 2023-08-15 Known Ransomware Use: Known Related CMMC/NIST Controls: IA-2 (Authentication Failures) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://forums.ivanti.com/s/article/CVE-2023-35078-Remote-unauthenticated-API-access-vulnerability?language=en_US; <https://nvd.nist.gov/vuln/detail/CVE-2023-35078>

CVE-2024-24919 · Check Point Quantum Security Gateways Information Disclosure Vulnerability Vendor: Check Point Product: Quantum Security Gateways Vulnerability Description: Check Point Quantum Security Gateways contain an unspecified information disclosure vulnerability. The vulnerability potentially allows an attacker to access information on Gateways connected to the internet, with IPsec VPN, Remote Access VPN or Mobile Access enabled. This issue affects several product lines from Check Point, including CloudGuard Network, Quantum Scalable Chassis, Quantum Security Gateways, and Quantum Spark Appliances. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-05-30 Remediation Due Date: 2024-06-20 Known Ransomware Use: Known Related CMMC/NIST Controls: AC-4 (Information Flow Enforcement) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.checkpoint.com/results/sk/sk182336> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-24919>

CVE-2024-38217 · Microsoft Windows Mark of the Web (MOTW) Protection Mechanism Failure Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows Mark of the Web (MOTW) contains a protection mechanism failure vulnerability that allows an attacker to bypass MOTW-based defenses. This can result in a limited loss of integrity and availability of security features such as Protected View in Microsoft Office, which rely on MOTW tagging. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-09-10 Remediation Due Date: 2024-10-01 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog

identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-38217>; <https://nvd.nist.gov/vuln/detail/CVE-2024-38217>

CVE-2025-22225 · VMware ESXi Arbitrary Write Vulnerability Vendor: VMware Product: ESXi Vulnerability Description: VMware ESXi contains an arbitrary write vulnerability. Successful exploitation allows an attacker with privileges within the VMX process to trigger an arbitrary kernel write leading to an escape of the sandbox. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-03-04 Remediation Due Date: 2025-03-25 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/25390> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-22225>

CVE-2025-22224 · VMware ESXi and Workstation TOCTOU Race Condition Vulnerability Vendor: VMware Product: ESXi and Workstation Vulnerability Description: VMware ESXi and Workstation contain a time-of-check time-of-use (TOCTOU) race condition vulnerability that leads to an out-of-bounds write. Successful exploitation enables an attacker with local administrative privileges on a virtual machine to execute code as the virtual machine's VMX process running on the host. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-03-04 Remediation Due Date: 2025-03-25 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://support.broadcom.com/web/ecx/support-content-notification/-/external/content/SecurityAdvisories/0/25390> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-22224>

CVE-2023-26083 · Arm Mali GPU Kernel Driver Information Disclosure Vulnerability Vendor: Arm Product: Mali Graphics Processing Unit (GPU) Vulnerability Description: Arm Mali GPU Kernel Driver contains an information disclosure vulnerability that allows a non-privileged user to make valid GPU processing operations that expose sensitive kernel metadata. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2023-04-07 Remediation Due Date: 2023-04-28 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://developer.arm.com/Arm%20Security%20Center/Mali%20GPU%20Driver%20Vulnerabilities>; <https://nvd.nist.gov/vuln/detail/CVE-2023-26083>

CVE-2024-21887 · Ivanti Connect Secure and Policy Secure Command Injection Vulnerability Vendor: Ivanti Product: Connect Secure and Policy Secure Vulnerability Description: Ivanti Connect Secure (ICS, formerly known as Pulse Connect Secure) and Ivanti Policy Secure contain a command injection vulnerability in the web components of these products, which can allow an authenticated administrator to send crafted requests to execute code on affected appliances. This vulnerability can be leveraged in conjunction with CVE-2023-46805, an authenticated bypass issue. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-01-10 Remediation Due Date: 2024-01-22 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: Please apply mitigations per vendor instructions. For more information, please see: https://forums.ivanti.com/s/article/KB-CVE-2023-46805-Authentication-Bypass-CVE-2024-21887-Command-Injection-for-Ivanti-Connect-Secure-and-Ivanti-Policy-Secure-Gateways?language=en_US ; <https://nvd.nist.gov/vuln/detail/CVE-2024-21887>

CVE-2023-7101 · Spreadsheet::ParseExcel Remote Code Execution Vulnerability Vendor: Spreadsheet::ParseExcel Product: Spreadsheet::ParseExcel Vulnerability Description: Spreadsheet::ParseExcel contains a remote code execution vulnerability due to passing unvalidated input from a file into a string-type `-eval-`. Specifically, the issue stems from the evaluation of Number format strings within the Excel parsing logic. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-01-02 Remediation Due Date: 2024-01-23 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: This vulnerability affects a common open-source component, third-party library, or a protocol used by different products. Please check with specific vendors for information on patching status. For more information, please see: <https://metacpan.org/dist/Spreadsheet-ParseExcel> and Barracuda's specific implementation and fix for their downstream issue CVE-2023-7102 at <https://www.barracuda.com/company/legal/esg-vulnerability>; <https://nvd.nist.gov/vuln/detail/CVE-2023-7101>

CVE-2024-21412 · Microsoft Windows Internet Shortcut Files Security Feature Bypass Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows Internet Shortcut Files contains an unspecified vulnerability that allows for a security feature bypass. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-02-13 Remediation Due Date: 2024-03-05 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2024-21412>; <https://nvd.nist.gov/vuln/detail/CVE-2024-21412>

CVE-2023-33538 · TP-Link Multiple Routers Command Injection Vulnerability Vendor: TP-Link Product: Multiple Routers Vulnerability Description: TP-Link TL-WR940N V2/V4, TL-WR841N V8/V10, and TL-WR740N V1/V2 contain a command injection vulnerability via the component `/userRpm/WlanNetworkRpm`. The impacted products could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-06-16 Remediation Due Date: 2025-07-07 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.tp-link.com/nordic/support/faq/3562/> ; <https://nvd.nist.gov/vuln/detail/CVE-2023-33538>

CVE-2025-48928 · TeleMessage TM SGNL Exposure of Core Dump File to an Unauthorized Control Sphere Vulnerability Vendor: TeleMessage Product: TM SGNL Vulnerability Description: TeleMessage TM SGNL contains an exposure of core dump file to an unauthorized control sphere Vulnerability. This vulnerability is based on a JSP application in which the heap content is roughly equivalent to a "core dump" in which a password previously sent over HTTP would be included in this dump. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-07-01 Remediation Due Date: 2025-07-22 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: It is recommended that mitigations be applied per vendor instructions if available. If these instructions cannot be located or if mitigations are unavailable, discontinue use of the product. ; <https://nvd.nist.gov/vuln/detail/CVE-2025-48928>

CVE-2024-38014 · Microsoft Windows Installer Improper Privilege Management Vulnerability Vendor: Microsoft Product: Windows Vulnerability Description: Microsoft Windows Installer contains an improper privilege management vulnerability that could allow an attacker to gain SYSTEM privileges. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if

mitigations are unavailable. Date Added to KEV: 2024-09-10 Remediation Due Date: 2024-10-01 Known Ransomware Use: Unknown Related CMMC/NIST Controls: AC-6 (Least Privilege) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-38014>; <https://nvd.nist.gov/vuln/detail/CVE-2024-38014>

CVE-2018-14667 · Red Hat JBoss RichFaces Framework Expression Language Injection Vulnerability Vendor: Red Hat Product: JBoss RichFaces Framework Vulnerability Description: Red Hat JBoss RichFaces Framework contains an expression language injection vulnerability via the UserResource resource. A remote, unauthenticated attacker could exploit this vulnerability to execute malicious code using a chain of Java serialized objects via `org.ajax4jsf.resource.UserResource$UriData`. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2023-09-28 Remediation Due Date: 2023-10-19 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://bugzilla.redhat.com/show_bug.cgi?id=CVE-2018-14667; <https://nvd.nist.gov/vuln/detail/CVE-2018-14667>

CVE-2025-15556 · Notepad++ Download of Code Without Integrity Check Vulnerability Vendor: Notepad++ Product: Notepad++ Vulnerability Description: Notepad++ when using the WinGUp updater, contains a download of code without integrity check vulnerability that could allow an attacker to intercept or redirect update traffic to download and execute an attacker-controlled installer. This could lead to arbitrary code execution with the privileges of the user. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2026-02-12 Remediation Due Date: 2026-03-05 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://notepad-plus-plus.org/news/clarification-security-incident/> ; <https://community.notepad-plus-plus.org/topic/27298/notepad-v8-8-9-vulnerability-fix> ; <https://nvd.nist.gov/vuln/detail/CVE-2025-15556>

CVE-2024-51567 · CyberPanel Incorrect Default Permissions Vulnerability Vendor: CyberPersons Product: CyberPanel Vulnerability Description: CyberPanel contains an incorrect default permissions vulnerability that allows a remote, unauthenticated attacker to execute commands as root. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-11-07 Remediation Due Date: 2024-11-28 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://cyberpanel.net/blog/details-and-fix-of-recent-security-issue-and-patch-of-cyberpanel> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-51567>

CVE-2022-27925 · Synacor Zimbra Collaboration Suite (ZCS) Arbitrary File Upload Vulnerability Vendor: Synacor Product: Zimbra Collaboration Suite (ZCS) Vulnerability Description: Synacor Zimbra Collaboration Suite (ZCS) contains flaw in the mboximport functionality, allowing an authenticated attacker to upload arbitrary files to perform remote code execution. This vulnerability was chained with CVE-2022-37042 which allows for unauthenticated remote code execution. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-08-11 Remediation Due Date: 2022-09-01 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://blog.zimbra.com/2022/08/authentication-bypass-in-mailboximportservlet-vulnerability/>; <https://nvd.nist.gov/vuln/detail/CVE-2022-27925>

CVE-2019-17621 · D-Link DIR-859 Router Command Execution Vulnerability Vendor: D-Link Product:

DIR-859 Router Vulnerability Description: D-Link DIR-859 router contains a command execution vulnerability in the UPnP endpoint URL, /gena.cgi. Exploitation allows an unauthenticated remote attacker to execute system commands as root by sending a specially crafted HTTP SUBSCRIBE request to the UPnP service when connecting to the local network. Required Action: Apply updates per vendor instructions or discontinue use of the product if updates are unavailable. Date Added to KEV: 2023-06-29 Remediation Due Date: 2023-07-20 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://supportannouncement.us.dlink.com/announcement/publication.aspx?name=SAP10147>; <https://nvd.nist.gov/vuln/detail/CVE-2019-17621>

CVE-2013-4810 · HP Multiple Products Remote Code Execution Vulnerability Vendor: Hewlett Packard (HP) Product: ProCurve Manager (PCM), PCM+, Identity Driven Manager (IDM), and Application Lifecycle Management Vulnerability Description: HP ProCurve Manager (PCM), PCM+, Identity Driven Manager (IDM), and Application Lifecycle Management allow remote attackers to execute arbitrary code via a marshalled object to (1) EJBIInvokerServlet or (2) JMXInvokerServlet. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-03-25 Remediation Due Date: 2022-04-15 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2013-4810>

CVE-2022-22620 · Apple iOS, iPadOS, and macOS Webkit Use-After-Free Vulnerability Vendor: Apple Product: iOS, iPadOS, and macOS Vulnerability Description: Apple iOS, iPadOS, and macOS WebKit contain a use-after-free vulnerability that leads to code execution when processing maliciously crafted web content. This vulnerability could impact HTML parsers that use WebKit, including but not limited to Apple Safari and non-Apple products which rely on WebKit for HTML processing. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-02-11 Remediation Due Date: 2022-02-25 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-16 (Use-After-Free Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2022-22620>

CVE-2022-44877 · CWP Control Web Panel OS Command Injection Vulnerability Vendor: CWP Product: Control Web Panel Vulnerability Description: CWP Control Web Panel (formerly CentOS Web Panel) contains an OS command injection vulnerability that allows remote attackers to execute commands via shell metacharacters in the login parameter. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2023-01-17 Remediation Due Date: 2023-02-07 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://control-webpanel.com/changelog#1669855527714-450fb335-6194>; <https://nvd.nist.gov/vuln/detail/CVE-2022-44877>

CVE-2024-20481 · Cisco ASA and FTD Denial-of-Service Vulnerability Vendor: Cisco Product: Adaptive Security Appliance (ASA) and Firepower Threat Defense (FTD) Vulnerability Description: Cisco Adaptive Security Appliance (ASA) and Firepower Threat Defense (FTD) contain a missing release of resource after effective lifetime vulnerability that could allow an unauthenticated, remote attacker to cause a denial-of-service (DoS) of the RAVPN service. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2024-10-24 Remediation Due Date: 2024-11-14 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://sec.cloudapps.cisco.com/security/center/content/CiscoSecurityAdvisory/cisco-sa-asafld-bf-dos-vDZhLqrW>; <https://nvd.nist.gov/vuln/detail/CVE-2024-20481>

CVE-2021-3493 · Linux Kernel Privilege Escalation Vulnerability Vendor: Linux Product: Kernel
Vulnerability Description: The overlayfs stacking file system in Linux kernel does not properly validate the application of file capabilities against user namespaces, which could lead to privilege escalation. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-10-20
Remediation Due Date: 2022-11-10 Known Ransomware Use: Unknown Related CMMC/NIST Controls: AC-3 (Access Enforcement) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://git.kernel.org/pub/scm/linux/kernel/git/torvalds/linux.git/commit?id=7c03e2cda4a584cad398e8f6641ca9988a39d52>; <https://nvd.nist.gov/vuln/detail/CVE-2021-3493>

CVE-2023-50224 · TP-Link TL-WR841N Authentication Bypass by Spoofing Vulnerability Vendor: TP-Link Product: TL-WR841N Vulnerability Description: TP-Link TL-WR841N contains an authentication bypass by spoofing vulnerability within the httpd service, which listens on TCP port 80 by default, leading to the disclosure of stored credentials. The impacted products could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-09-03 Remediation Due Date: 2025-09-24 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://www.tp-link.com/us/support/faq/4308/>; <https://nvd.nist.gov/vuln/detail/CVE-2023-50224>

CVE-2021-40407 · Reolink RLC-410W IP Camera OS Command Injection Vulnerability Vendor: Reolink Product: RLC-410W IP Camera Vulnerability Description: Reolink RLC-410W IP cameras contain an authenticated OS command injection vulnerability in the device network settings functionality. Required Action: The impacted product could be end-of-life (EoL) and/or end-of-service (EoS). Users should discontinue product utilization if a current mitigation is unavailable. Date Added to KEV: 2024-12-18 Remediation Due Date: 2025-01-08 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://reolink.com/product-eol/>; <https://reolink.com/download-center/>; <https://nvd.nist.gov/vuln/detail/CVE-2021-40407>

CVE-2024-12987 · DrayTek Vigor Routers OS Command Injection Vulnerability Vendor: DrayTek Product: Vigor Routers Vulnerability Description: DrayTek Vigor2960, Vigor300B, and Vigor3900 routers contain an OS command injection vulnerability due to an unknown function of the file /cgi-bin/mainfunction.cgi/apmcfupload of the component web management interface. Required Action: Apply mitigations per vendor instructions, follow applicable BOD 22-01 guidance for cloud services, or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-05-15 Remediation Due Date: 2025-06-05 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Input Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: https://fw.draytek.com.tw/Vigor2960/Firmware/v1.5.1.5/DrayTek_Vigor2960_V1.5.1.5_01release-note.pdf; https://fw.draytek.com.tw/Vigor300B/Firmware/v1.5.1.5/DrayTek_Vigor300B_V1.5.1.5_01release-note.pdf; https://fw.draytek.com.tw/Vigor3900/Firmware/v1.5.1.5/DrayTek_Vigor3900_V1.5.1.5_01release-note.pdf; <https://nvd.nist.gov/vuln/detail/CVE-2024-12987>

CVE-2020-3452 · Cisco ASA and FTD Read-Only Path Traversal Vulnerability Vendor: Cisco Product: Adaptive Security Appliance (ASA) and Firepower Threat Defense (FTD) Vulnerability Description: Cisco Adaptive Security Appliance (ASA) and Firepower Threat Defense (FTD) contain an improper input validation vulnerability when HTTP requests process URLs. An attacker could exploit this vulnerability by sending a crafted HTTP request containing directory traversal character sequences to an affected device. A successful exploit could allow the attacker to view arbitrary files within the web services file system on the targeted device. Required Action: Apply updates per vendor

instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2020-3452>

CVE-2013-5223 · D-Link DSL-2760U Gateway Cross-Site Scripting Vulnerability Vendor: D-Link Product: DSL-2760U Vulnerability Description: A cross-site scripting (XSS) vulnerability exists in the D-Link DSL-2760U gateway, allowing remote authenticated users to inject arbitrary web script or HTML. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2022-03-25 Remediation Due Date: 2022-04-15 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (Cross-Site Scripting Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2013-5223>

CVE-2021-44026 · Roundcube Webmail SQL Injection Vulnerability Vendor: Roundcube Product: Roundcube Webmail Vulnerability Description: Roundcube Webmail is vulnerable to SQL injection via search or search_params. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2023-06-22 Remediation Due Date: 2023-07-13 Known Ransomware Use: Unknown Related CMMC/NIST Controls: SI-10 (SQL Injection Prevention) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://roundcube.net/news/2021/11/12/security-updates-1.4.12-and-1.3.17-released>; <https://nvd.nist.gov/vuln/detail/CVE-2021-44026>

CVE-2018-6789 · Exim Buffer Overflow Vulnerability Vendor: Exim Product: Exim Vulnerability Description: Exim contains a buffer overflow vulnerability in the base64d function part of the SMTP listener that may allow for remote code execution. Required Action: Apply updates per vendor instructions. Date Added to KEV: 2021-11-03 Remediation Due Date: 2022-05-03 Known Ransomware Use: Known Related CMMC/NIST Controls: SI-16 (Memory Protection) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://nvd.nist.gov/vuln/detail/CVE-2018-6789>

CVE-2023-46604 · Apache ActiveMQ Deserialization of Untrusted Data Vulnerability Vendor: Apache Product: ActiveMQ Vulnerability Description: Apache ActiveMQ contains a deserialization of untrusted data vulnerability that may allow a remote attacker with network access to a broker to run shell commands by manipulating serialized class types in the OpenWire protocol to cause the broker to instantiate any class on the classpath. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2023-11-02 Remediation Due Date: 2023-11-23 Known Ransomware Use: Known Related CMMC/NIST Controls: SI-10 (Deserialization Validation) Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://activemq.apache.org/security-advisories.data/CVE-2023-46604-announcement.txt>; <https://nvd.nist.gov/vuln/detail/CVE-2023-46604>

CVE-2024-29059 · Microsoft .NET Framework Information Disclosure Vulnerability Vendor: Microsoft Product: .NET Framework Vulnerability Description: Microsoft .NET Framework contains an information disclosure vulnerability that exposes the ObjRef URI to an attacker, ultimately enabling remote code execution. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-02-04 Remediation Due Date: 2025-02-25 Known Ransomware Use: Unknown Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-29059> ; <https://nvd.nist.gov/vuln/detail/CVE-2024-29059>

CVE-2023-48365 · Qlik Sense HTTP Tunneling Vulnerability Vendor: Qlik Product: Sense Vulnerability
Description: Qlik Sense contains an HTTP tunneling vulnerability that allows an attacker to escalate privileges and execute HTTP requests on the backend server hosting the software. Required Action: Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable. Date Added to KEV: 2025-01-13 Remediation Due Date: 2025-02-03 Known Ransomware Use: Known Compliance Context: Organizations subject to CMMC must maintain vulnerability management processes (RA-5) and apply security patches in a timely manner (SI-2). The CISA KEV catalog identifies vulnerabilities that are actively exploited and require priority remediation under BOD 22-01. Notes: <https://community.qlik.com/t5/Official-Support-Articles/Critical-Security-fixes-for-Qlik-Sense-Enterprise-for-Windows/tac-p/2120510> ; <https://nvd.nist.gov/vuln/detail/CVE-2023-48365>